

Sentinel: Engineering Decisions Log

Every Key Decision, Alternative, and Trade-off

For Samsung Solve for Tomorrow IRIS ISEF

Sentinel ? Engineering Decisions Log

Every Key Decision, Alternative, and Trade-off

| # | Component | Decision | Why | Alternative(s) | Trade-off |

1	Auth	bcrypt password hashing	Simple, mature, stdlib, well-audited	Argon2id	Argon2id has better GPU/ASIC resistance; migration
2	Auth	HS256 JWT (symmetric)	Simpler than asymmetric for 2-service architecture	RS256	No public-key verification without sharing secret; acceptable for Docker network
3	Auth	8-hour token, no refresh	Covers clinical workday; re-auth = re-unlock	Refresh tokens	User re-authenticates daily; ensures passphrase is fresh
4	Auth	5-failure lockout, 15-min cooldown	Simple, effective brute-force protection	Progressive delay (1s/2s/5s)	No gradual slowdown; lockout triggers after 5 rapid attempts
5	Crisis	Thread-based countdown (daemon threads)	Isolates crisis state from request handler	AsyncIO tasks, Celery, Redis scheduler	Threads don't survive restart; acceptable for single-server
6	Crisis	Singleton crisis state (one active crisis)	Simplifies WebSocket broadcast UI	Per-patient crisis	Scales to 30 patients in pilot; per-patient mode planned
7	Crisis	20x time compression for testing	Makes 60s escalation testable in 3s	Mock timers, real-time testing	Compression is linear; results extrapolate correctly
8	Discrepancy	Rule-based classifier, zero ML	Deterministic, auditable, 0.1ms	TF-IDF, DistilBERT, Neural fusion	Misses sarcasm/negation/clinical jargon; calibrated for over-sensitivity
9	Discrepancy	Two word sets (18 positive, 22 negative)	Simple, extendable to new languages	N-gram models, embedding similarity	No semantic understanding; "not happy" contains "happy" = false positive
10	Encryption	Fernet (AES-128-CBC + HMAC)	Bundles auth, timestamp, serialization	Raw AES-GCM	128-bit vs 256-bit key; Fernet's bundled format reduces implementation bugs
11	Encryption	PBKDF2 600K iterations	NIST range 100-300ms; our result: 154.8ms	scrypt, Argon2id	Not memory-hard; ASIC-resistant but not ASIC-proof
12	Encryption	HKDF-Expand for key separation	Cryptographic independence between Fernet and HMAC keys	Single derived key	Adds a derivation step (~0.01ms); best practice per Ferguson et al.
13	Storage	SQLite with WAL mode	Atomic transactions, concurrent reads, B-tree indexing	JSON files, PostgreSQL, MongoDB	19ms slower on bulk writes vs JSON; file-level vs network database
14	Storage	SQLAlchemy ORM	DB-agnostic; PostgreSQL migration is one env var change	Raw SQL, SQLAlchemy Core	ORM overhead (~5%); enables flexible deployment without code changes
15	Storage	String timestamps (ISO format)	Timezone-safe, works identically across DB backends	Native DateTime columns	Date-range queries use lexicographic string comparison; no DB date functions
16	AI	Ollama local inference (primary)	Zero network dependency; data never leaves clinic	OpenAI API, Groq Cloud	7.2B model requires ~8GB RAM; slower than cloud (200-500ms vs 50-100ms)
17	AI	Three-tier fallback (Ollama ? Groq ? Rules)	System always returns a response	Single provider	Rule-based fallback is less accurate but deterministic; safe for triage
18	AI	Regex-based JSON extraction from LLM output	Practical: LLMs wrap JSON in markdown/fences	Structured output mode (not available in Ollama)	Fragile parsing; works with sentinel fine-tune (~95% compliance)
19	Audit	Hash-chained audit log (SHA-256)	Tamper-evident; modify historical row = break chain	Full blockchain,	

append-only file | Not tamper-proof (attacker with DB access can recompute chain) |

| 20 | Audit | Centralized log_audit() with optional db session | Works in request context and background tasks | Per-module logging | All-or-nothing; no selective log level filtering |

| 21 | Frontend | React 19 + TypeScript + Vite 6 | Type safety, fast builds, small bundle | Streamlit, Next.js, Pure JS | Streamlit couldn't handle role-based routing; Next.js SSR is unnecessary for gated SPA |

| 22 | Frontend | Custom pub/sub auth store (no Redux) | 50 lines vs 100+ lines of Redux boilerplate | Redux, Zustand, Context API | No DevTools, no middleware; fine for single global state variable |

| 23 | Frontend | Emoji icons (no icon library) | Zero dependency, 56 KB production bundle | lucide-react, Font Awesome, Heroicons | Not customizable (color, size); acceptable trade-off for minimal bundle |

| 24 | Frontend | localStorage for JWT | Simple, persists across browser restarts | HttpOnly cookies, sessionStorage | XSS vulnerability; localStorage is accessible to any JS on the page |

| 25 | Deployment | Docker Compose (local) + Render (cloud) | Identical deployment on laptop, clinic server, or cloud | Heroku, AWS ECS, bare metal | Docker adds ~200MB per image; two commands (docker compose up) to deploy |

| 26 | Deployment | Non-root user in backend container | Security: exploit gives restricted user, not root | Root execution | Setup complexity; compatible with most Docker orchestration platforms |

| 27 | Deployment | Multi-stage frontend build (Node ? nginx) | 20MB production image; no build tools in runtime | Single-stage image | Adds build stage complexity; saves ~500MB per deployment |

| 28 | Security | hmac.compare_digest() for HMAC verification | Constant-time comparison; prevents timing attack | Python == operator | Single-line fix; eliminates byte-by-byte timing oracle |

| 29 | Security | Pydantic Literal type for role constraint | Compile-time validation at API boundary | String validation in business logic | Schema-level enforcement; invalid roles rejected before any DB query |

| 30 | Benchmark | Custom CSV logbook (not pytest-benchmark) | IRIS-standard format for academic reproducibility | pytest-benchmark, ASV | Single-run per test (no confidence intervals); designed for paper, not CI |

| 31 | Auth | HttpOnly cookie for JWT | Prevents XSS token theft | localStorage only | Cookie requires browser auto-send; localStorage fallback for programmatic clients |

| 32 | Encryption | EncryptedText TypeDecorator | Transparent data-at-rest encryption at ORM layer | Raw Text columns | ~0.5ms overhead per read/write; pre-unlock plaintext data becomes inaccessible |

| 33 | Security | RateLimiterMiddleware (100 req/min per IP) | Basic DDoS protection without Redis infrastructure | slowapi, Redis token bucket | In-memory state resets on server restart; not distributed |

| 34 | Security | DOMPurify frontend sanitization | Defense-in-depth XSS prevention | Server-side HTML stripping, CSP headers | Client-side sanitization bypassable if attacker controls JS bundle |

| 35 | Deployment | Internal Docker network (internal: true) | Backend unreachable from LAN | Host network mode, default bridge | All API traffic must route through frontend Nginx proxy |

| 36 | Security | Global exception handler with sanitized 500s | Prevents stack trace leakage in error responses | Default FastAPI tracebacks | Debugging requires server log access instead of client error details |

| 37 | Discrepancy | Negation-aware keyword stripping | Handles "not happy" via _strip_negated_words() | Simple substring matching | 4-word window may miss distant negation; English-only prefix set |

| 38 | Discrepancy | neutral+low_stress no longer triggers alert | Reduces false positives for healthy biometrics | Original: neutral+any_extreme = alert | May miss dissociation cases with calm biometrics |

| 39 | Storage | backup_wal() for DB file copies | Crash recovery beyond WAL journal mode | Cloud replication, RAID hardware | Same filesystem; doesn't protect against drive failure |

| 40 | AI | Ollama request queuing with threading Lock | Prevents thundering herd on low-cost hardware | AsyncIO semaphore, Redis queue | Serializes concurrent requests; 500ms min gap adds latency under load |

| 41 | Encryption | Selective field encryption (3 of 11 tables) | Non-sensitive metadata stays queryable | Encrypt all 11 tables | Only patient-identifiable content is encrypted |

| 42 | Auth | /auth/logout clears HttpOnly cookie | Server-side logout for browser sessions | Client-side localStorage.removeItem only | No stateful blacklist; sufficient for LAN deployment with 8hr expiry |

| 43 | Hardware | Per-device token auth (X-Device-Serial + X-Device-Token) | Physical rings must not share patient

passwords | Patient JWT only, per-ring TLS certs | Tokens are bearer credentials; hashed (SHA-256) at rest, constant-time compared |

| 44 | Hardware | ring_devices binding table with revoked flag | Central revocation + re-pair lifecycle | Stateless token without DB row | One DB row per device; revoked serials get fresh tokens on re-pair |

| 45 | Hardware | Pluggable RingSource adapter SDK | One base contract, N devices | Device-specific code paths in API layer | Adapter writers must implement the contract; JSON normalization is their job |

| 46 | Hardware | bleak as bridge-only dependency (requirements-bridge.txt) | BLE stack is optional for deployment | Core dependency, OS-native BLE | Ring bridge host must pip install -r requirements-bridge.txt |

| 47 | Hardware | Canonical SensorData payload for all adapters | Single ingestion schema, normalized units | Raw vendor payloads stored per-source | Unit normalization is an adapter responsibility, not the API's |

| 48 | Hardware | Deterministic SimulatedRing (seeded per user + hour) | Reproducible demos and tests without hardware | Random/statistical generation | Patterns are synthetic; must not be mistaken for real patient data |

| 49 | Hardware | Single POST /ring/data endpoint for every adapter | Adding a device never touches API/engine code | Per-vendor endpoints | All normalization happens inside adapters, before authentication |

| 50 | AI | Dual-mode summarization (companion vs clinical OAP) | Same journal, two audiences; companion tone avoids clinical alarm | One clinical-only output | Extra prompt path; both share the deterministic three-tier fallback |

Summary

All 22 vulnerabilities identified during penetration testing are now patched: 10 original critical/high findings, 6 additional hardening measures, 3 architectural improvements, and 3 documentation/operational fixes. Hardware M0 added the device-binding/authentication layer (rows 43-49) verified by 9 ring API/SDK tests and an end-to-end device-to-database push.

Quick Reference: What Would You Do Differently With Unlimited Resources?

1. Argon2id for password hashing and key derivation
2. Redis pub/sub for multi-process WebSocket scaling
3. PostgreSQL for production multi-server deployment
4. Alembic for database migration management
5. Refresh tokens with HttpOnly cookie storage
6. Rate limiting (slowapi + Redis) on auth endpoints
7. Content Security Policy headers
8. Per-patient crisis states instead of singleton
9. Chart.js / D3 for biometric trend visualization
10. CI pipeline (GitHub Actions) for automated benchmark regression

Key Defensible Positions (For Judges)

- **Rule-based over ML for triage:** A deterministic system with 100% auditable accuracy is safer than a probabilistic system with 94% accuracy when false negatives are lethal**
- **SQLite over PostgreSQL for clinic deployment:** Zero-config, zero-DBA, zero-cost ? and fully migratable when scale demands it**
- **Local AI over cloud AI:** Works during internet outages, zero data leaving the clinic, no per-token cost**
- **Custom auth over OAuth2:** No third-party dependency, works offline, two-factor with encryption unlock**
- **Threads over tasks for crisis:** Immediate, cancellable execution without broker infrastructure**

Prepared for Samsung Solve for Tomorrow ? IRIS ? ISEF 2026

~25,000 lines | 54 benchmarks | 22 security patches + device-token auth | 21-page paper